

Clase 043 — Network Security Monitoring (NSM): fundamentos

Parte: 1 — Redes y seguridad de redes · Fuente: *The Practice of Network Security Monitoring*, R. Bejtlich

 Duración estimada: 120 min · Nivel: Avanzado

Objetivo

Introducir el **Network Security Monitoring** como disciplina: la recolección, análisis y escalado de indicadores de red para detectar y responder a intrusiones, partiendo de la premisa de que la prevención eventualmente falla. El alumno conocerá los tipos de datos NSM, el ciclo de detección y las plataformas que lo implementan (Security Onion).

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Explicar** la filosofía NSM y por qué "la prevención falla".
2. **Distinguir** los tipos de datos NSM (full content, sesión, transacción, extraídos, alertas, estadísticos, metadatos).
3. **Ubicar** correctamente los sensores en la red.
4. **Recorrer** el ciclo detección → análisis → escalado → respuesta.
5. **Desplegar** una plataforma NSM de laboratorio (Security Onion).
6. **Realizar** análisis dirigido por indicadores y por hipótesis (threat hunting básico).

Temas

#	Tema	Por qué importa
1	Filosofía NSM (Bejtlich)	Marco mental defensivo
2	Tipos de datos NSM	Qué recolectar y por qué
3	Colocación de sensores	Visibilidad efectiva
4	Ciclo de detección y respuesta	Operar el monitoreo
5	Security Onion	Plataforma integrada
6	Detección por indicadores vs. hunting	Reactivo y proactivo
7	Métricas y cobertura	Medir el programa

Definiciones y características

- **NSM:** recolección, análisis y escalado de indicaciones y advertencias para detectar y responder a intrusiones; asume que el atacante entrará y busca detectarlo pronto.

- **Full content data:** captura completa de paquetes (pcap); máxima fidelidad, alto coste de almacenamiento.
- **Session/flow data:** resumen de conexiones (5-tupla, bytes, duración); eficiente y muy útil para investigación.
- **Transaction data:** registros de protocolo de alto nivel (peticiones HTTP, consultas DNS, handshakes TLS) como los que produce Zeek.
- **Alert data:** salidas de IDS/IPS (Suricata/Snort) que señalan coincidencias con firmas.
- **Threat hunting:** búsqueda proactiva de amenazas guiada por hipótesis, sin depender de una alerta previa.

Herramientas y preparación

- **Security Onion 2.x** (distribución NSM que integra Suricata, Zeek, Stenographer, Elastic, Kibana).
- Alternativa ligera: Suricata + Zeek + un almacén de logs propio.
- Un TAP/SPAN o interfaz de captura en el laboratorio con tráfico representativo.
- Recursos: una VM con suficiente RAM (Security Onion pide bastante).

 **Nota ética:** el NSM implica capturar y almacenar tráfico, que puede contener datos personales. Monitoriza solo redes que administras, con base legal y políticas de privacidad claras (avisos a usuarios, retención mínima). En laboratorio, usa tu propio tráfico.

Laboratorio guiado

1. **Despliega Security Onion** en una VM (modo import/eval para laboratorio) y accede a su consola web.
2. **Importa un pcap** representativo (o el `lab027.pcapng` de clases previas) mediante `so-import-pcap`:

```
bash sudo so-import-pcap /ruta/lab027.pcapng
```

3. **Explora las alertas** en la interfaz (Alerts): identifica qué firmas de Suricata dispararon.
4. **Pivota a los logs de Zeek:** para una alerta, abre los registros de sesión (`conn.log`), HTTP (`http.log`) y DNS (`dns.log`) asociados.
5. **Recupera el full content:** desde una alerta, extrae el pcap del flujo y ábrelo en Wireshark para el análisis fino.
6. **Recorre el ciclo NSM:** documenta detección (alerta) → análisis (logs + pcap) → decisión (falso positivo o incidente) → escalado.
7. **Hunting por hipótesis:** plantea "¿hay beaconing hacia un dominio raro?" y búscalo en `conn.log` / `dns.log` por frecuencia y regularidad de conexiones.

Ejercicios

1. Clasifica cada dato de un incidente en su tipo NSM (full content, sesión, transacción, alerta...).
2. Justifica dónde colocarías un sensor para monitorizar el tráfico entre la DMZ y la red interna.
3. A partir de una alerta, reconstruye la sesión completa usando los logs de Zeek.
4. Formula tres hipótesis de threat hunting y describe qué dato NSM usarías para cada una.
5. Explica el compromiso entre retención de full content y coste de almacenamiento.
6. Define tres métricas para medir la eficacia de un programa NSM (p. ej. tiempo medio de detección).

Reto verificable

Con Security Onion (o Suricata+Zeek), procesa una captura que contenga actividad sospechosa (un escaneo y una descarga anómala que generes en tu laboratorio) y produce un "expediente" NSM del evento: la alerta que lo detectó, los logs de sesión y transacción que lo contextualizan, y el pcap del flujo. Concluye si es incidente o falso positivo y por qué.

Criterio de aceptación: el expediente enlaza correctamente alerta → logs → full content del mismo flujo, y la conclusión (incidente/falso positivo) está fundamentada en la evidencia recolectada.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Security Onion sin datos	Sensor mal configurado o interfaz de monitoreo equivocada; revisa la config de captura
Demasiadas alertas, nadie las mira	Falta afinado y priorización; ajusta reglas y define un flujo de triaje
Solo se guardan alertas, no contexto	Sin session/transaction data no puedes investigar; habilita Zeek y retención de flujos
Disco lleno por full content	Retención de pcap demasiado larga; limita por tiempo/tamaño y prioriza sesiones
Sensor sin visibilidad	Mal colocado (no ve el tráfico relevante); usa TAP/SPAN en el punto correcto

Preguntas frecuentes

? ¿NSM es lo mismo que un IDS? No. El IDS (alertas por firmas) es **una** fuente de datos dentro del NSM. El NSM abarca también sesión, transacción, full content y el proceso humano de análisis y respuesta.

? ¿Por qué guardar tráfico si tengo un IDS? Porque las firmas no lo detectan todo. Con datos de sesión y full content puedes investigar incidentes que ninguna firma alertó y reconstruir lo ocurrido.

? ¿NSM sustituye a la prevención? No, la complementa. Parte de que la prevención fallará y se centra en detectar y responder rápido para reducir el impacto.

? ¿Qué es threat hunting? La búsqueda proactiva de amenazas guiada por hipótesis (no por alertas), usando los datos NSM para encontrar actividad maliciosa que pasó desapercibida.

Referencias

- Bejtlich, R. *The Practice of Network Security Monitoring*. No Starch Press. <https://nostarch.com/nsm>
- Sanders, C. & Smith, J. *Applied Network Security Monitoring*. Syngress.
- Security Onion documentation. <https://docs.securityonion.net/>
- SANS — NSM and Threat Hunting resources. <https://www.sans.org/>

Siguiente clase

Clase 044 - Zeek para analisis de red a gran escala